

NIST Cybersecurity Framework Gap Analysis

Current-state maturity assessment and remediation roadmap aligned to NIST CSF

Client / Entity	HealthData Cloud (fictional)
Prepared By	GRC Analyst Portfolio
Framework Basis	NIST Cybersecurity Framework
Document Type	Gap Analysis Report
Version	1.0

Prepared by Gustavo do Carmo Lemes to practice structured maturity assessment against the NIST Cybersecurity Framework, using a fictional organization as the assessment subject.

1. Executive Summary

This NIST Cybersecurity Framework assessment evaluates the current maturity of a fictional growth-stage healthcare SaaS company against the five core CSF functions: Identify, Protect, Detect, Respond, and Recover. The current state reflects partial maturity with stronger response planning than preventive and detective control coverage.

The overall profile indicates that foundational governance practices exist, but implementation consistency remains uneven. Highest-priority gaps relate to identity management, logging and monitoring, vulnerability management discipline, and recovery testing.

2. Maturity Scale

Score	Definition
1	Not Established - control is absent or ad hoc
2	Initial - control exists informally or inconsistently
3	Defined - control is documented and partly operationalized
4	Managed - control is consistently implemented and monitored
5	Optimized - control is measured, improved, and integrated into governance

3. Selected Findings

CSF Function	Observation	Risk Implication	Priority
Identify	Asset inventory exists but is not fully automated	Security teams may miss unmanaged assets and software	High
Protect	MFA is not enforced across all user populations	Increased likelihood of unauthorized access	Critical
Detect	Application and cloud logs are not centrally correlated	Potentially delayed detection of security events	Critical
Respond	Incident plan exists but tabletop exercises are irregular	Reduced coordination under high-pressure incidents	Medium
Recover	Backups are performed but restoration tests are limited	Recovery assumptions may not match real-world disruption	High

4. Target-State Roadmap

1. Implement a centralized asset and software inventory for critical environments.
2. Deploy MFA for all workforce identities and privileged workflows.
3. Centralize logging and define detection use cases for identity, endpoint, cloud, and application events.
4. Operationalize vulnerability management with service-level expectations by severity.
5. Run semiannual tabletop exercises and annual backup restoration tests with documented lessons learned.